

02

Ameaças, Malwares e Engenharia Social

Golpes, vulnerabilidades, ataques, DoS/DDoS e fatores humanos

Curso Técnico em Desenvolvimento de Sistemas

Capítulo planejado para aproximadamente 4 horas-aula

Material de apoio didático • teoria, laboratório e revisão

Base curricular

Este capítulo foi estruturado a partir das bases tecnológicas do componente Segurança de Sistemas de Informação do curso Técnico em Desenvolvimento de Sistemas do Centro Paula Souza. A coleção expande a ementa com exemplos e atividades de laboratório.

Objetivos de aprendizagem

- Reconhecer categorias comuns de ameaças e malwares.
- Entender como golpes e engenharia social exploram comportamento humano.
- Diferenciar indisponibilidade acidental, DoS e DDoS.
- Propor medidas de prevenção, detecção e resposta adequadas ao contexto.

Alinhamento curricular

Aprofunda a habilidade curricular de identificar ameaças à segurança da informação e desenvolver criticidade diante de mensagens, links, arquivos e comportamentos suspeitos.

1. Como pensar em ameaças

Ameaças podem ter origem externa ou interna, ser intencionais ou acidentais e explorar falhas técnicas, humanas ou processuais. Um erro de configuração pode expor um serviço sem que exista malware; uma senha reutilizada pode permitir invasão mesmo com sistema atualizado.

Para analisar uma ameaça, pergunte: quem ou o que poderia causar o evento, qual ativo seria afetado, qual fraqueza permitiria isso, quais sinais apareceriam e como reduzir o impacto.

2. Malware: famílias e comportamento

Malware é software criado ou adaptado para produzir comportamento malicioso. Vírus depende de um hospedeiro e costuma se propagar ao executar arquivos infectados. Worm se espalha de forma autônoma. Trojan se apresenta como legítimo. Ransomware busca indisponibilizar dados, frequentemente por criptografia, para extorsão. Spyware coleta informações. Backdoors criam acesso oculto.

Os nomes ajudam a descrever comportamento, mas incidentes reais podem combinar técnicas. A defesa moderna não pode depender somente de reconhecer um arquivo conhecido: atualização, privilégio mínimo, segmentação, backup, filtragem e monitoramento reduzem várias classes de ataque ao mesmo tempo.

Tipo	Característica principal
Vírus	Depende de arquivo/hospedeiro e execução.
Worm	Propaga-se de forma autônoma.
Trojan	Disfarça-se como conteúdo legítimo.
Ransomware	Busca indisponibilizar dados para extorsão.
Spyware	Coleta informações sem autorização.

3. Phishing e engenharia social

Engenharia social manipula pessoas para obter ação, informação ou acesso. Phishing tenta induzir a vítima por mensagens falsas; spear phishing é mais direcionado. Golpistas exploram urgência, autoridade, curiosidade, medo e recompensa. Em empresas, pedidos falsos de alteração de conta bancária ou redefinição de senha são exemplos frequentes.

A resposta não deve depender apenas de “atenção do usuário”. Processos precisam dificultar o golpe: autenticação multifator, confirmação por canal independente para operações sensíveis, filtros de e-mail, limites de privilégio e cultura que permita reportar suspeitas rapidamente.

4. DoS e DDoS

Negação de serviço ocorre quando recursos legítimos ficam indisponíveis por esgotamento de processamento, memória, conexões, banda ou capacidade da aplicação. Em DoS, a origem pode ser concentrada; em DDoS, múltiplos sistemas participam do tráfego malicioso.

Mitigações incluem dimensionamento, rate limiting, filas, cache, proteção na borda, redes de distribuição de conteúdo, filtros e arquitetura resiliente. Também é importante distinguir ataque de pico legítimo ou falha de software para não reagir ao problema errado.

5. Indicadores e resposta inicial

Possíveis sinais incluem aumento anormal de autenticações falhas, processos desconhecidos, tráfego incomum, alterações inesperadas, lentidão repentina, alertas do endpoint e criação de contas não autorizadas. Um único sinal não prova ataque; a análise combina contexto e evidências.

Em suspeita de incidente, preservar evidências e seguir o procedimento institucional costuma ser melhor do que “investigar” de forma improvisada. Isolamento, registro de horário, comunicação aos responsáveis e recuperação por fontes confiáveis são ações típicas.

Laboratório e aplicação prática

Prática 2 - Oficina de reconhecimento de phishing

Objetivo: Analisar sinais de engenharia social sem interagir com links ou anexos reais.

Regra de laboratório

Use apenas exemplos fictícios ou mensagens previamente sanitizadas. Não abra links, anexos ou QR codes desconhecidos durante a atividade.

1. Crie três mensagens fictícias: uma legítima, uma suspeita e uma claramente fraudulenta.
2. Marque elementos de contexto, remetente, urgência, domínio, pedido de credenciais e anexos.
3. Defina quais verificações podem ser feitas sem clicar em links.
4. Elabore um procedimento de confirmação para pedidos financeiros ou troca de senha.
5. Escreva uma mensagem curta de orientação a usuários não técnicos.

Entrega sugerida: Um checklist de validação de mensagens e um fluxo de reporte de suspeitas.

Questões de fixação

1. Por que um antivírus não elimina o risco de engenharia social?
2. Diferencie worm, trojan e ransomware.
3. Qual é a diferença conceitual entre DoS e DDoS?
4. Cite três controles que reduzem o impacto de ransomware.
5. Por que confirmação por canal independente é importante em operações sensíveis?

Como estudar

Responda primeiro sem consultar o texto. Depois compare sua resposta com o resumo do capítulo e complemente o que faltou.

Resumo do capítulo

- Ameaças podem explorar tecnologia, pessoas e processos.
- Malwares variam no modo de execução e propagação, mas controles em camadas reduzem múltiplas classes.
- Engenharia social explora confiança e pressão psicológica; processos devem compensar limitações humanas.
- DoS e DDoS afetam disponibilidade e exigem medidas arquiteturais e operacionais.
- Resposta inicial deve priorizar evidência, contenção e procedimento institucional.

Glossário essencial

Termo	Definição
Malware	Software com comportamento malicioso.
Phishing	Tentativa de enganar usuários por mensagens ou páginas falsas.
Ransomware	Malware associado à extorsão e indisponibilidade de dados.
DoS	Negação de serviço originada por uma ou poucas fontes.
DDoS	Negação de serviço distribuída por múltiplas fontes.
Indicador	Sinal observável que pode contribuir para identificar um incidente.

Referências e materiais de consulta

- Centro Paula Souza. Plano de Curso do Técnico em Desenvolvimento de Sistemas, componente Segurança de Sistemas de Informação.
- CERT.br. Cartilha de Segurança para Internet. Conteúdo de conscientização e boas práticas de segurança.
- ISO/IEC 27001. Sistemas de gestão de segurança da informação - requisitos e princípios de gestão.
- OWASP Foundation. OWASP Top 10:2025 e materiais de segurança de aplicações web.